Ransomware Detection and Defence

Ransomware has emerged as one of the most disruptive and financially devastating forms of cybercrime in recent years. Unlike traditional malware that silently steals data, ransomware makes itself known by encrypting critical files and demanding payment before the victim can regain access. The impact extends beyond financial loss, causing operational downtime, reputational damage, and in critical sectors such as healthcare or infrastructure, potentially life-threatening consequences.

Effective defence against ransomware is not a single solution but a layered strategy. Organisations must be equipped to detect threats early, respond swiftly, and recover with minimal damage. This requires a combination of technical controls, behavioural monitoring, and incident response planning working in concert across the environment.

The case study examined in this section — the Cerber ransomware attack on Wayne Enterprises — demonstrates how a single USB device inserted into one workstation can cascade into a full network compromise within minutes. By reconstructing the attack using Splunk and following the Lockheed Martin Cyber Kill Chain, it is possible to identify where detection could have occurred earlier and where defensive controls should have been in place.

The Anatomy of a Ransomware Attack — A Case Study

To illustrate how ransomware operates in a real-world environment, this section presents an investigative scenario based on the Splunk Boss of the SOC (BOTS) workshop. The persona adopted is that of Alice Buber, a newly hired analyst tasked with protecting and defending Wayne Enterprises.

On her second day in the role, Alice is called into her manager's office. One of the organisation's users has been greeted by a ransom note on their Windows desktop, claiming that files on the system have been encrypted and that payment must be made to recover them. The machine has been infected with Cerber ransomware, and Alice's objective is clear: investigate the attack and reconstruct exactly how it unfolded, step by step.

Using Splunk as the primary investigation tool and guided by the Lockheed Martin Cyber Kill Chain, the following analysis uncovers the full attack timeline — from the initial infection vector through to the final ransom redirection.

Step 1: The Crime Scene — Identifying the Victim

The first step in any ransomware investigation is to establish the identity of the compromised machine. Given the hostname `we8105desk` and the known date of the attack — 24 August 2016 — Splunk was queried against the botsv1 dataset. Analysis of the returned results revealed that the IP address `192.168.250.100` appeared most frequently as a source, confirming it as the infected host. Establishing this early is critical, as all subsequent queries are filtered against this IP and hostname.

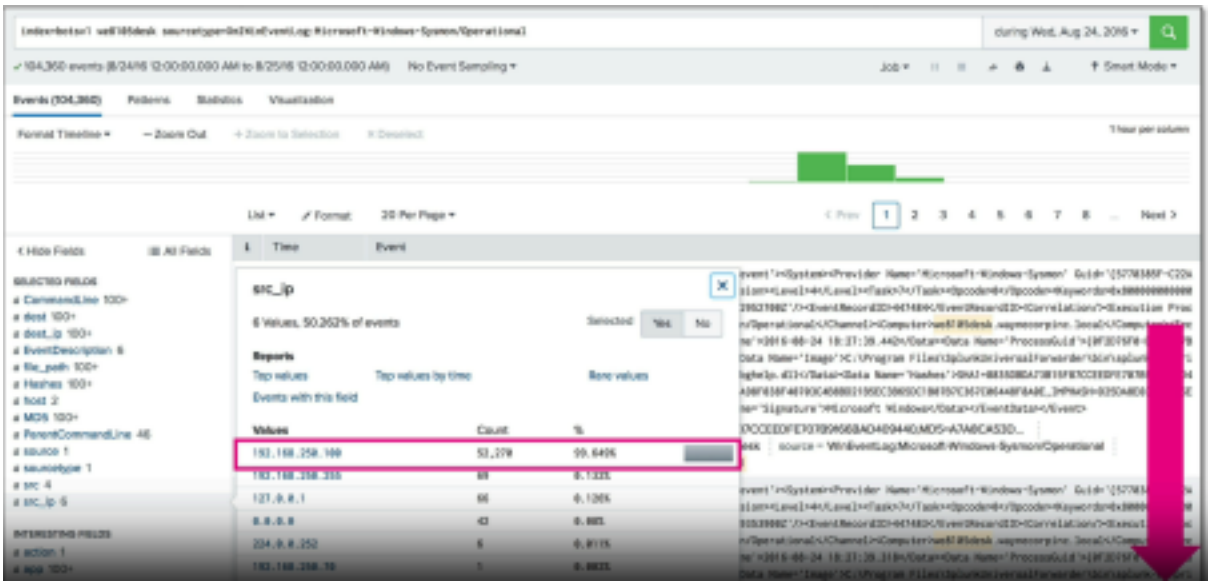
Analyst Insight: *Without this, everything else is guesswork.*

Splunk Query:

index="botsv1" host=we8105desk

Finding: Victim IP → `192.168.250.100` | Hostname → `we8105desk` ***Screenshot:***

Splunk results showing 192.168.250.100 as most prevalent source IP



Step 2: The Weapon Brought In — Tracing the USB Device

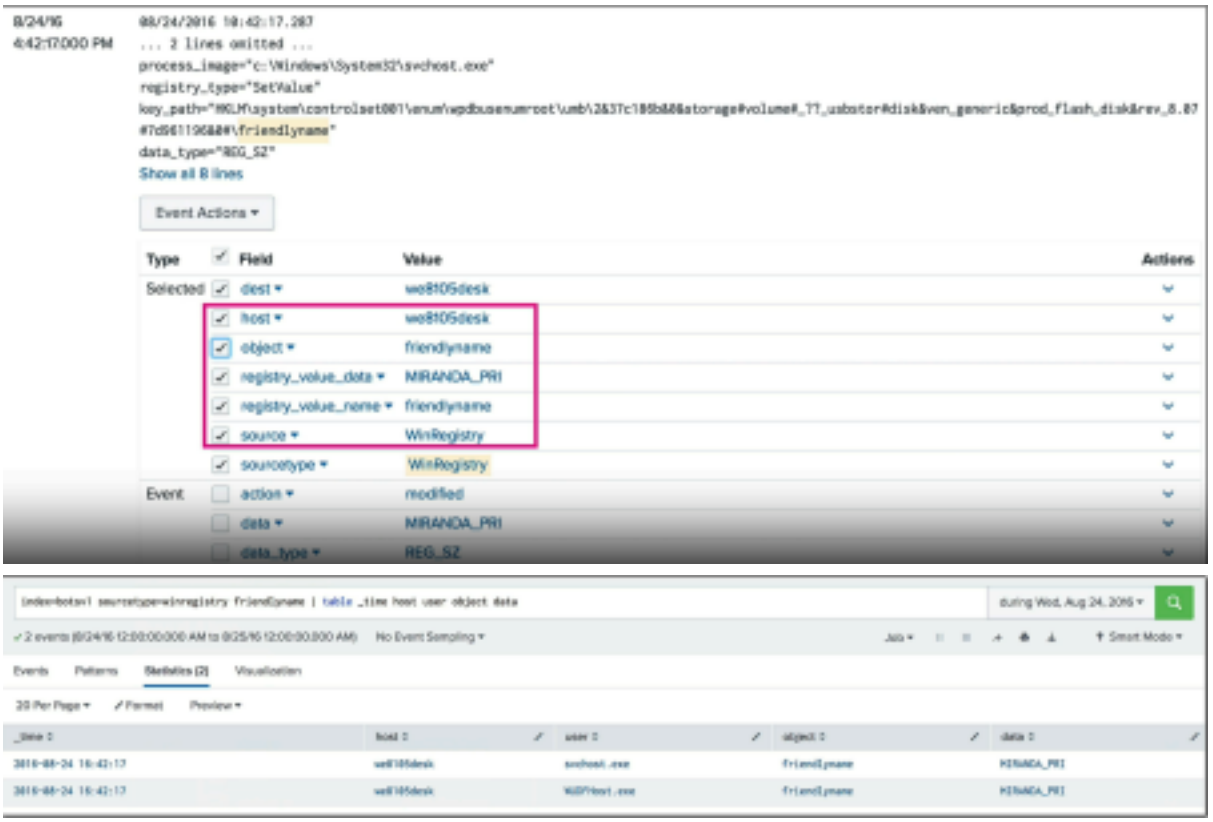
With USB-based infection suspected, the Windows Registry was examined, as it records configuration data including information about hardware connected to the system. Querying the registry for the `FriendlyName` field — which stores the human-readable name of connected USB devices — returned a clear result. A USB drive named MIRANDA_PRI had been inserted into the infected workstation. This is a significant finding, as the same device could potentially have been used across multiple machines.

Analyst Insight: *This is the initial infection vector — the attacker walked in through the front door.*

Splunk Query:

index="botsv1" sourcetype=winregistry friendlyname
Finding: USB Device Name → `MIRANDA_PRI`

Screenshot: *Windows Registry result showing MIRANDA_PRI as FriendlyName*



Step 3: Pulling the Trigger — The Malicious File Executed

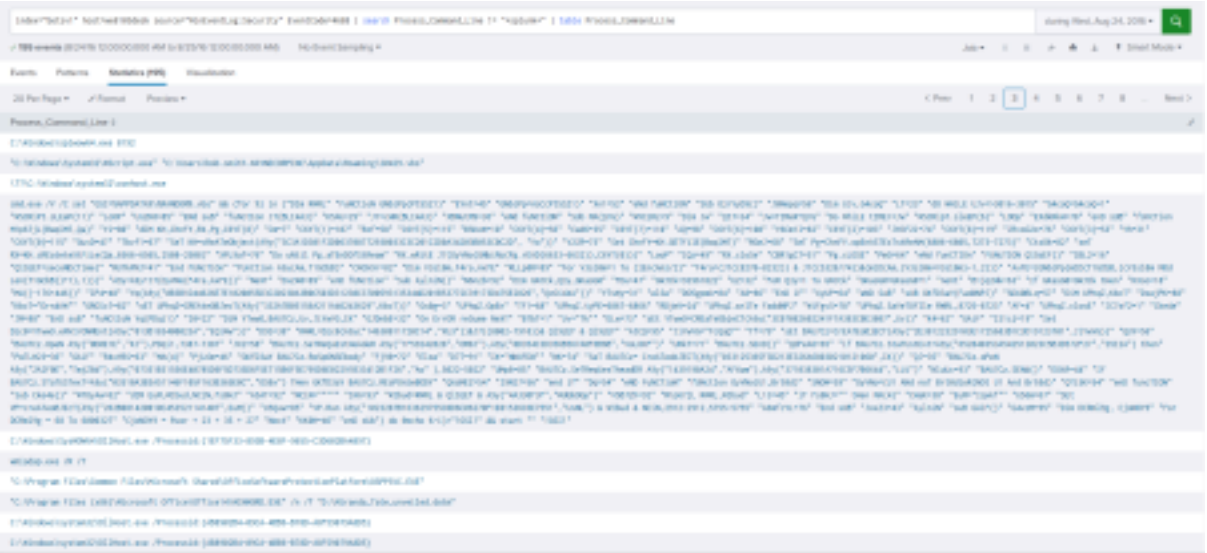
Following USB insertion, the attacker's file was executed on the host. To identify this, Windows Security Event logs were examined using Event ID 4688, which records newly created processes. After filtering out legitimate system noise such as Splunk-related executables, the results narrowed from 939 to 195 events. Manual review of the remaining command lines revealed that a file named Miranda_Tate_unveiled.dotm was opened shortly after the USB insertion, which subsequently spawned two additional processes — `cmd.exe` and `splwow64.exe` — confirming this as the payload launcher.

Analyst Insight: *This is the moment the attack was set in motion.*

Splunk Query:
index="botsv1" host=we8105desk source="WinEventLog:Security" EventCode=4688
| search Process_Command_Line != "*splunk*" | table Process_Command_Line

Finding: Malicious File → `Miranda_Tate_unveiled.dotm` | Spawned → `cmd.exe`, `splwow64.exe`

**** ***Screenshot:*** *Security event log showing .dotm file execution and spawned processes*



Step 4: Calling the Mastermind — First Malicious Domain Contact

With internal connections established, attention turned to external network communication. DNS event logs were queried for Type A record lookups originating from the victim IP. After filtering out known legitimate domains — including Microsoft, Bing, and internal Wayne Enterprises domains — the first suspicious external domain contacted was identified as solidaritedeproximite.org. This domain had been reported as malicious by the security community and represents the first point of attacker-controlled external communication.

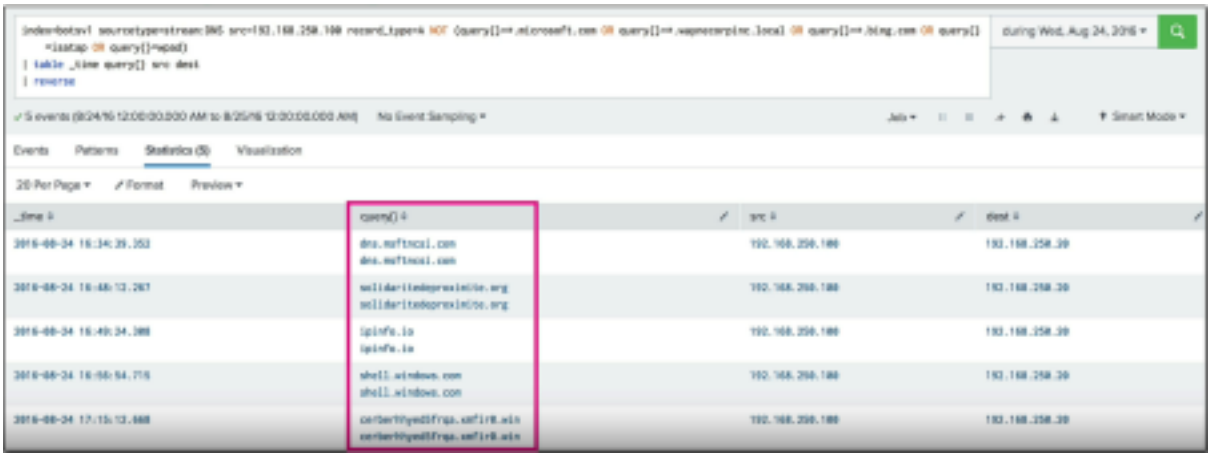
Analyst Insight: *The malware phoned home — this is the attacker's*

infrastructure. Splunk Query:

```
index="botsv1" sourcetype="stream:dns" src_ip="192.168.250.100" record_type=A
NOT (query=*.microsoft.com OR query=*.live.com OR query=*.waynecorpinc.local OR
query=*.bing.com OR query=wpad OR query=isatap)
| table _time query src dest
| sort - _time
| reverse
```

Finding: First malicious domain → `solidaritedeproximite.org`

Screenshot: *DNS log showing solidaritedeproximite.org as first suspicious external domain*



Step 5: Delivering the Payload — The Cryptor File Downloaded

To identify the ransomware cryptor code, HTTP stream logs and Suricata network security logs were examined for outbound connections from the victim host. The investigation uncovered that a file named mhtr.jpg had been downloaded — disguised as an image file but confirmed as the Cerber cryptor payload. Firewall logs from the fgt-utm source further corroborated this, flagging the file as malicious shortly after download. This step confirms the origin and filename of the ransomware component responsible for file encryption.

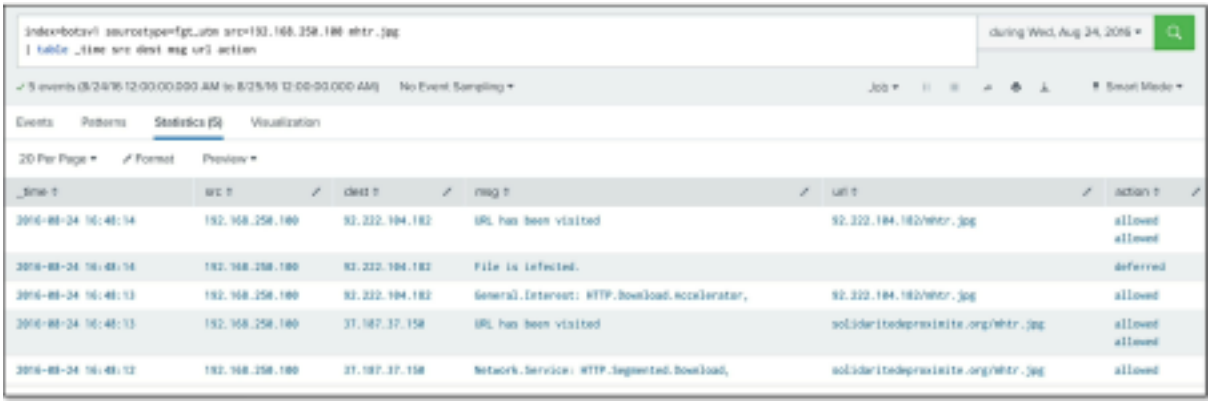
> **Analyst Insight:** *The weapon was now inside the building — disguised as an innocent image file.*

Splunk Query:

```
index="botsv1" src_ip="192.168.250.100" sourcetype="stream:http"
| stats count values(url) by dest
```

Finding: Cryptor file downloaded → `mhtr.jpg` | Confirmed malicious by firewall logs

Screenshot: *HTTP stream and Suricata results showing mhtr.jpg download*



Step 6: Following the Trail — Mapping the Process Chain

To fully reconstruct the attack sequence, the relationship between processes was mapped

using Sysmon logs. A suspicious temporary file — 121214.tmp — had been flagged by threat intelligence. Querying for this filename alongside `CommandLine` and `ParentCommandLine` fields produced a clear chronological chain of process execution. The results confirmed that the parent process ID was 3968, and that the attack followed a logical sequence from the initial `.dotm` file through to the cryptor execution.

> **Analyst Insight:** *Every process left a footprint — this is how we reconstructed the full attack sequence.*

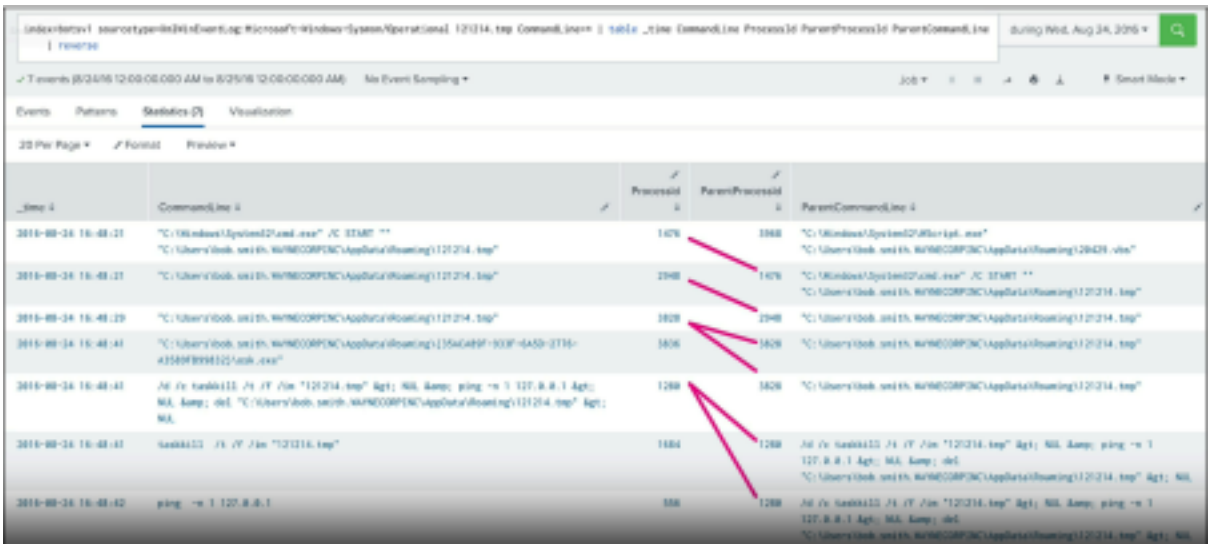
Splunk Query:

```
index="botsv1" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational"
121214.tmp CommandLine=* ParentCommandLine=*
| table _time CommandLine ParentCommandLine ProcessId ParentProcessId
| sort - _time
| reverse
```

Finding: Suspicious temp file → `121214.tmp` | Parent Process ID → `3968`

Attack Chain: `Miranda_Tate_unveiled.dotm` ➡ `cmd.exe` ➡ `VBScript` ➡ `121214.tmp` ➡ `mhtr.jpg (cryptor)`

Screenshot: *Sysmon table showing full parent-child process chain*



Step 7: Counting the Casualties — Encrypted Local Files

To measure the extent of local damage on Bob Smith's workstation, Sysmon logs were queried for `.txt` file activity, filtered specifically by the event description "File Create Time" to capture newly created encrypted files. The distinct count of affected text files provided a quantifiable measure of local damage on the victim's machine, giving investigators a clear picture of how many files were compromised on the endpoint itself.

> **Analyst Insight:** *Every number here represents a file the victim could no longer open.*

Splunk Query:

index="botsv1" sourcetype="XmlWinEventLog:Microsoft-Windows-Sysmon/Operational" we8105desk *.txt EventDescription="File Create Time"

Finding: Distinct count of encrypted `.txt` files on `we8105desk` confirmed

Screenshot: Sysmon results showing distinct count of encrypted text files on victim workstation

TargetFilename

>100 Values, 100% of events

Selected Yes No

Reports

Top values | Top values by time | Rare values

Events with this field

Top 10 Values	Count	%
C:\Sysmon\._Eula.txt	1	0.244%
C:\Sysmon\AuditPol_AFTER_WE8105DESK.txt	1	0.244%
C:\Sysmon\AuditPol_BEFORE_WE8105DESK.txt	1	0.244%
C:\Sysmon\Eula.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Office 2010 Pro\Key.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Project 2010\Key.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\2010\Visio 2010\visio 2010.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\._Help.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\._readme.txt	1	0.244%
C:\Users\bob.smith.WAYNECORPINC\Desktop\BootCamp4for7\Drivers\Intel\Chipset\Help.txt	1	0.244%

Step 8: The Wider Damage — Encrypted Files on the Server

Given the confirmed connection between the infected workstation and the file server `we9041srv`, Windows event logs on the server were queried for PDF file activity. Using a distinct count of the `Relative_Target_Name` field, the number of unique PDF files encrypted on the shared server was determined. This step is critical as it extends the damage assessment beyond the initial host and quantifies the broader organisational impact of the attack on shared network resources.

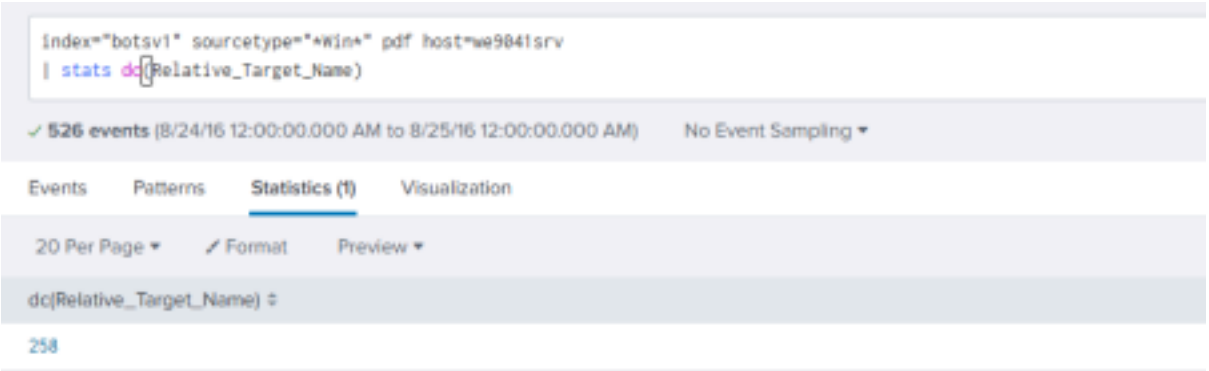
> **Analyst Insight:** *The damage was not limited to one desk — it reached the entire organisation's shared files.*

Splunk Query:

index="botsv1" sourcetype="*Win*" pdf host=we9041srv
| stats dc(Relative_Target_Name)

Finding: Distinct count of encrypted `.pdf` files on file server `we9041srv` confirmed

Screenshot: Windows event log result showing distinct PDF count on we9041srv



Step 9: The Attacker's Final Move — Post-Encryption Ransom Redirection

The final step of the investigation examined where affected users were directed following encryption — typically a payment portal operated by the attacker. Returning to the DNS logs and applying the same filtering technique used in Step 6, the domain to which the victim's browser was redirected after encryption was identified. This domain forms part of the attacker's payment infrastructure and provides valuable intelligence about the threat actor's operational setup. Reporting this domain to relevant threat intelligence platforms can assist in disrupting the attacker's wider campaign.

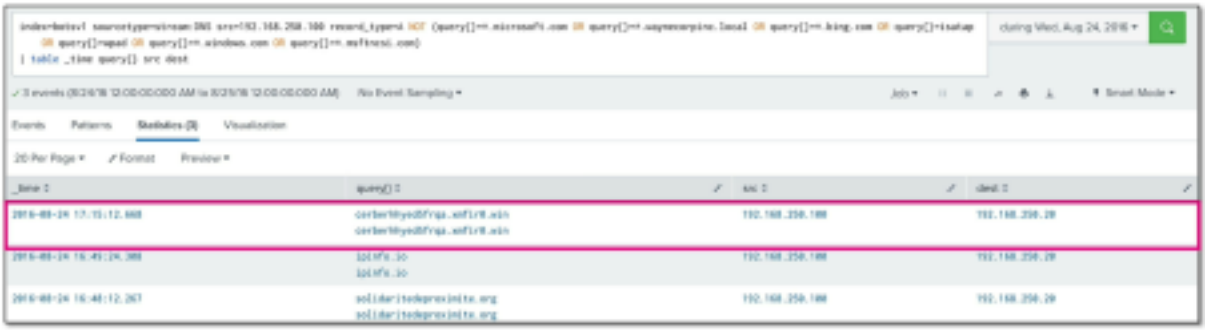
> **Analyst Insight:** *This is where the attacker waited to collect — the final destination of the attack.*

Splunk Query:

index="botsv1" sourcetype="stream:dns" src=192.168.250.100 record_type=A NOT (query=*.microsoft.com OR query=*.live.com OR query=*.waynecorpinc.local OR query=*.bing.com OR query=wpad OR query=isatap)
| table _time query src dest

Finding: Post-encryption redirection domain identified — attacker's ransom payment portal confirmed

Screenshot: *DNS log showing final domain redirection after encryption*



Ransomware Summary

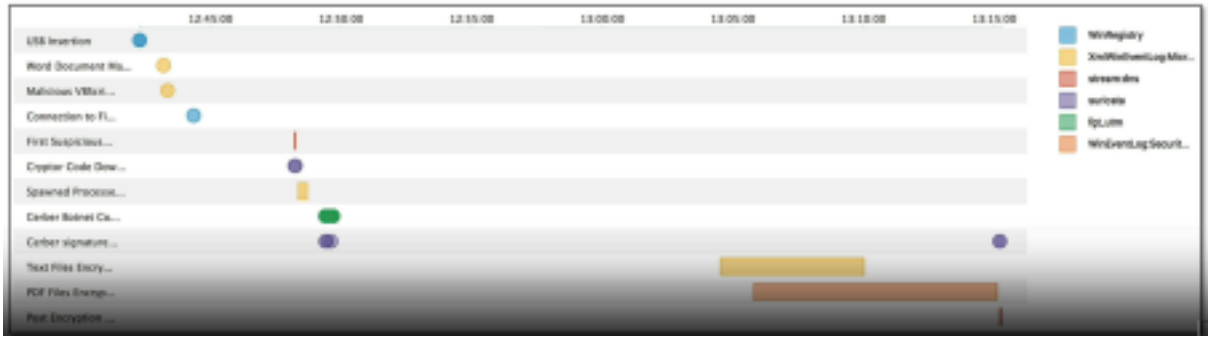
User (or someone) inserted an infected USB drive into Bob Smith's workstation (not sure why!?!)

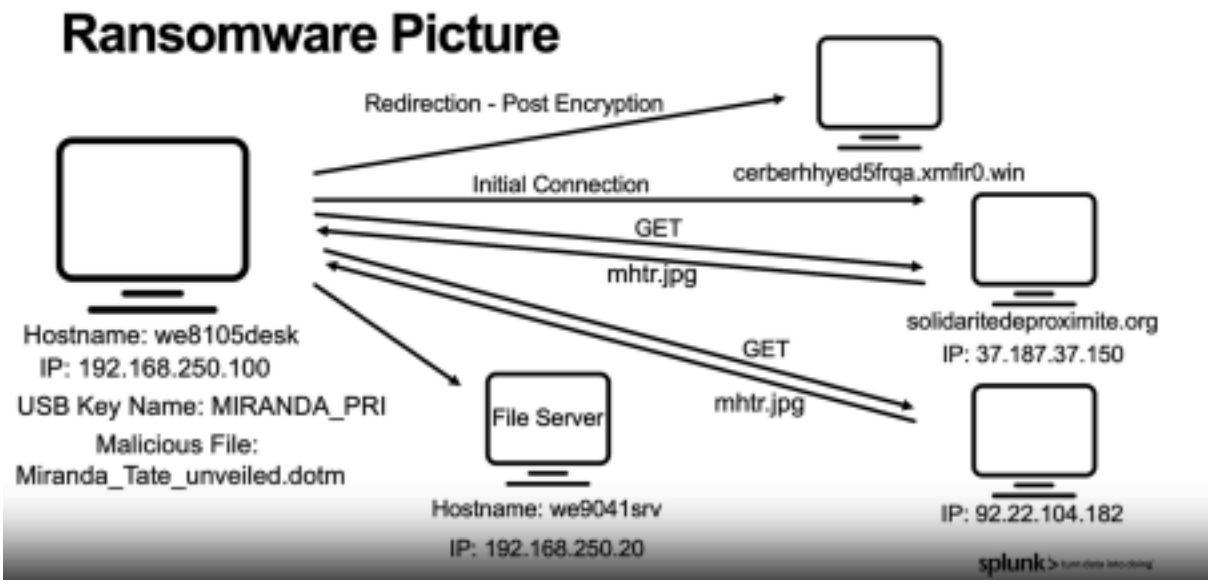
Word document spawned a Suspicious Process which spawned additional processes

File was downloaded after calls were made to a FQDN and IP address

Encryption of files begin on both local disk and shares

Redirection to an external site with notification of encryption occurred





Detection Strategies

Effective ransomware detection requires visibility across endpoints, networks, and logs. The Cerber attack demonstrated that indicators of compromise were present at every stage, but without the right monitoring in place, they went unnoticed until it was too late.

A Security Information and Event Management (SIEM) system such as Splunk is the most critical detection capability, allowing analysts to ingest and correlate logs from multiple sources simultaneously — Windows Security events, Sysmon, DNS streams, and firewall logs. This enables rapid identification of suspicious patterns and unexpected network

behaviour across the environment.

Intrusion Detection Systems (IDS) such as Suricata complement this by monitoring network traffic for known threat signatures. However, as demonstrated in this case where one signature fired 25 minutes after execution, signature-based detection alone is insufficient. Behavioural monitoring — flagging abnormally long command strings, unusual DNS lookups, and unexpected outbound connections — must be configured alongside it.

Endpoint Detection and Response (EDR) tools provide real-time monitoring of process creation and file system changes. Had EDR been active on `we8105desk`, the spawning of `cmd.exe` from a `.dotm` file would likely have triggered an immediate alert before the cryptor was even downloaded.

Defence and Prevention Measures

The Cerber attack exploited several preventable weaknesses, each mapping to a specific defensive control.

USB device control policies should be enforced through Group Policy, allowing only pre-approved devices to connect to corporate machines. This alone would have prevented the initial infection vector entirely. Disabling macros by default in Microsoft Office, particularly for documents originating from external sources, would have stopped `Miranda_Tate_unveiled.dotm` from executing its payload.

Network segmentation and least privilege access would have prevented the ransomware from reaching the file server `we9041srv`. DNS filtering integrated with threat intelligence feeds would have blocked the connection to `solidaritedeproximite.org` before the cryptor file could be downloaded.
Regular offline backups following the 3-2-1 rule — three copies, two media types, one offsite — remain one of the most effective defences, ensuring recovery without paying the ransom. User awareness training should also be maintained to ensure employees recognise suspicious devices and unexpected files as potential threats.

Incident Response

When ransomware is detected, the immediate priority is containment — isolating the infected machine from the network to prevent further encryption of shared resources. Earlier isolation of `we8105desk` would have prevented the attack from reaching the file server entirely.

Following containment, the scope of infection must be determined — identifying all affected machines, encrypted files, and attacker-controlled domains. Eradication then involves reimaging compromised endpoints and blocking all identified attacker infrastructure at the firewall and DNS level. Recovery is achieved by restoring data from clean backups once the infection vector has been addressed.

Law enforcement agencies including Europol and the FBI advise against paying the ransom, as it funds criminal activity and does not guarantee file recovery.

Lessons Learned from the Cerber Attack

The Cerber attack succeeded not because of sophistication, but because of preventable failures at multiple points in the kill chain. The USB should never have connected without authorisation. The macro should never have executed. The malicious domain should have been blocked. The file server should not have been directly accessible from a standard user workstation.

Ransomware succeeds not because defenders lack tools, but because those tools are not configured or integrated effectively. A layered security posture combining endpoint controls, network monitoring, user training, and a tested incident response plan would have disrupted this attack long before any files were encrypted.